AOU
الجامعة العربية المفتوحة
Arab Open University
Faculty of Computer Studies

TM256
Cyber Security

Final Examination
Summer Semester 2025/2026

Time Allowed: 3 hours

AOU EGYPT

Instructions:

- Total Marks: **50**
- This exam consists of **3** parts.
- **ALL questions** must be answered in the External Answer booklet.
- Be sure you write your **name and ID** on the External Answer booklet.
- **Calculators** are allowed.

الجامعة العربية المفتوحة - مصر
Arab Open University
القبول والتسجيل
الامتحانات
Arab Republic of Egypt

CamScanner

PART 1: Multiple Choice Questions [10 Marks]

Question 1: Choose the correct answer for the following questions:

1. Which of the following best describes phishing?
   a) Encrypting data to keep it safe
   b) Monitoring traffic for threats
   c) Tricking someone into revealing personal information
   d) Protecting devices from physical damage
2. Which method is used to authenticate email headers and identify spoofed addresses?
   a) SPF
   b) DKIM
   c) HTTPS
   d) STARTTLS
3. In a known-plaintext attack, the adversary has access to:
   A) Only the ciphertext uses statistical analysis to detect patterns in the encrypted data
   B) The ability to choose any plaintext and observe the resulting ciphertext in order to deduce the key
   C) Both the original plaintext and its corresponding ciphertext, using these pairs to attempt to determine the encryption key
   D) The source code of the cryptographic algorithm being used to encrypt the target data
4. What is the key difference between host-based and hardware firewalls?
   A) Host-based firewalls protect entire networks, while hardware firewalls protect only individual devices
   B) Hardware firewalls require software installation, while host-based firewalls do not
   C) Host-based firewalls protect individual devices, while hardware firewalls protect network traffic
   D) Host-based firewalls filter traffic at the network level
5. How does virtualization enhance application security?
   a) By isolating applications within virtual environments, reducing the impact of a breach on other applications
   b) By allowing unlimited data sharing between applications
   c) By encrypting all network traffic by default
   d) By automatically applying security updates
6. An Intrusion Prevention System (IPS) differs from an Intrusion Detection System (IDS) in that an IPS:
   A) Monitors only inbound network traffic, whereas an IDS monitors both inbound and outbound traffic
   B) Requires a security analyst to manually confirm each alert before any protective action is taken
   C) Actively blocks or drops malicious network traffic in real time, rather than only detecting and raising alerts
   D) Operates exclusively at the application layer and cannot analyse traffic at the network layer

الجامعة العربية المفتوحة - مصر
Arab Open University
القبول والتسجيل
الامتحانات

CamScanner

7. How does DevSecOps improve security in software development?
   A) By performing security checks only at the final stage
   B) By removing security restrictions from developers
   C) By making security an optional component
   D) By integrating security at every phase of development
8. A SQL injection attack is BEST described as:
   A) Intercepting and modifying HTTP traffic flowing between a user's browser and a web server
   B) Embedding malicious scripts into web pages that are then executed by other users' browsers
   C) Exploiting a buffer overflow vulnerability in web server software to execute arbitrary code remotely
   D) Inserting malicious SQL commands into user-supplied input fields to manipulate or extract data from a web application's database
9. The principal objectives of a Security Operations Center (SOC) include which of the following?
   A) To develop and maintain the organization's cyber insurance policies and manage regulatory reporting obligations
   B) To conduct post-breach forensic investigations exclusively on behalf of law enforcement authorities
   C) To oversee the detection of and response to threats, increase organizational resilience, and identify criminal or negligent behavior
   D) To manage procurement negotiations with third-party security vendors and cloud service providers
10. Which of the following is the PRIMARY security risk associated with Bring Your Own Device (BYOD) policies in an organization?
   A) Personal devices are incompatible with enterprise wireless network protocols and cannot join the corporate network
   B) Personal devices are typically unmanaged and may not comply with the organization's security policies and standards
   C) Employees who use personal devices for work are legally prohibited from processing any sensitive organizational data
   D) Personal devices cannot receive operating system patches or security updates from the organization's IT team

PART 2: Short Questions [20 Marks]

Question 2: What are the main usability factors contributing to security failures? [3 Marks]

Question 3: How does the MITRE ATT&CK model help cybersecurity professionals detect and respond to cyberattacks? [4 Marks]

Question 4: What is a monolithic operating system, and what are some advantages and security concerns associated with it? [4 Marks]

الجامعة العربية المفتوحة - مصر
Arab Open University
القبول والتسجيل
الامتحانات
Arab Republic of Egypt

CamScanner

Question 5: Explain the role of Security Information and Event Management (SIEM) in detecting and managing security incidents. [3 Marks]

Question 6: What is the purpose of using a Web Application Firewall (WAF)? [3 Marks]

Question 7: Explain the concept of sandboxing and discuss its importance in application testing and infrastructure security. [3 Marks]

PART 3: Problem questions [20 Marks]

Question 8: Alice wants to use the RSA algorithm to encrypt a message. She chooses two prime numbers, p = 3 and q = 11. [6 Marks]

1. The modulus n
2. Euler's totient $\varphi(n)$.
3. Choose a public key exponent e
4. Compute the private key exponent d
5. Write the public and the private keys.

Question 9: An e-commerce company operates a web application where customers search for products. The security team receives a report that an attacker has extracted the names, email addresses, and hashed passwords of over 10,000 customers from the company's database. Initial investigation confirms that no firewall rules were violated and no malware was detected on any server. [7 Marks]

(a) Identify the most likely attack type and explain the mechanism by which it allowed data extraction without triggering the firewall. [3 marks]
(b) The web server is connected directly to the Internet with no DMZ in place. Explain how deploying the application inside a DMZ architecture would have limited the impact of this attack. [2 marks]
(c) Recommend TWO specific application-level controls that the development team should implement to prevent this attack in the future. Justify each recommendation. [2 marks]

Question 10: A logistics company suspects that a senior accounts manager, who has handed in their notice and whose last working day is tomorrow, has been copying confidential client contracts to a personal USB drive. The IT manager proposes immediately logging into the employee's workstation on the live system, opening recently accessed files, and reviewing the USB activity log directly. [7 Marks]

(a) Identify TWO serious errors in the IT manager's proposed approach from a digital forensics perspective and explain the consequences of each. [2 marks]
(b) Describe the correct first TWO steps of the digital forensic process that should be applied in this situation before any examination of data takes place. [2 marks]
(c) After a forensic image is created, the examiner finds a folder named "Client_Contracts_Copy" that was created on a USB drive three days ago. The IT manager declares, "This proves the employee stole the data." Critically evaluate this statement with reference to the distinction between forensic findings and facts. [3 marks]

End of questions

الجامعة العربية المفتوحة - مصر
Arab Open University
القبول والتسجيل
الامتحانات
Arab Republic of Egypt

CamScanner